

Cybersecurity Risk Assessment & Threat Modeling — Volvo Case Study

OCTAVE Allegro | NIST SP 800-30 | NIST CSF 2.0 | STRIDE

Carlos Leanos



Introduction

Company: Volvo (global automotive manufacturer)

Industry: Automotive / Manufacturing

Market: Global, high-value IP, supply chain dependent

Purpose: Assess cybersecurity risks & protections



Data Classification

Risk is evaluated based on likelihood and impact, with priority given to protecting Tier 3 (important/confidential) assets that pose the highest risk to the organization.

Data Classification

Tier 1

Publicly Available

- Website
- Press Release
- Marketing Materials

Tier 2

Internal Use

- Customer Data
- Employee Data
- Internal Documents

Tier 3

Confidential

- Financial Records
- Blueprints
- Intellectual Property



Justification

Methodology Chosen

OCTAVE Allegro (Primary), Supported by NIST SP 800-30 (Supporting Framework)

Why OCTAVE?

- Asset-focused (protects high-value data)
- Practical and efficient
- Supports real-world risk scenarios

How Risk is Evaluated

- Risk determined using Likelihood vs Impact
- Focus on Tier 3 assets
- Scenarios analyzed: ransomware, insider threats, supply chain attacks

Why OCTAVE Allegro + NIST SP 800-30?

- Requires extensive data and formal modeling
- Better suited for long-term / large-scale assessments

Impact Assessment

Business Impact

- Costs associated with incident response, forensic investigations, and remediation
- Potential ransom demands from attackers
- Long-term losses if proprietary technology is exposed to competitors

Operational Impact

- Temporary shutdown or isolation of affected systems
- Disruption of product development processes
- Increased cybersecurity review and system audits

Reputational Impact

- Damage to customer and investor confidence
- Concerns about protection of intellectual property
- Potential regulatory scrutiny regarding data protection practices



Security Gaps Relevant to Supply-Chain

Risk

Current State

- Partial MFA Implementation
- Insufficient segmentation
- Inconsistent access control and monitoring
- Legacy systems increase vulnerability risk

Potential Relationship to Identified Gaps

- Limited MFA coverage → could increase credential-related risk
- Insufficient segmentation → could increase the potential for lateral movement
- Weak third-party controls → increase exposure through trusted vendor relationships.

Recent Incident

2025 Volvo Supply Chain Data Breach (Miljödata)



Unauthorized access to HR systems
(third-party vendor breached)



Employee personal data exposed
(names, SSNs leaked)



Risk of identity theft & reputational damage

Threat

Scenarios

Compromised Credentials

- Credential theft → unauthorized access to systems and repositories
- High risk due to weak IAM controls

API / Application Vulnerabilities

- Weak API validation and access control
- Can expose sensitive data or allow manipulation

Ransomware & IP Theft

- Targeting automotive industry IP and production systems
- Extortion threats tied to data exposure

Third-Party / Supply Chain Risk

- Vendors introduce external attack paths
- Connected systems increase exposure

Proposed Countermeasures: Identity & Access Management (IAM)

Goal: Prevent unauthorized access

- Enforce MFA for all users
- Implement Privileged Access Management (PAM)
- Apply least privilege principle.
- Strong passwords + account lockout



Proposed Countermeasures: Monitoring & Detection

Goal: Detect threats in real time

- Deploy SIEM and EDR tools
- Monitor endpoints
- Track repeated failed login attempts
- Centralize logs for visibility



Proposed Countermeasures: Infrastructure & Resilience

Goal: Reduce impact of attacks

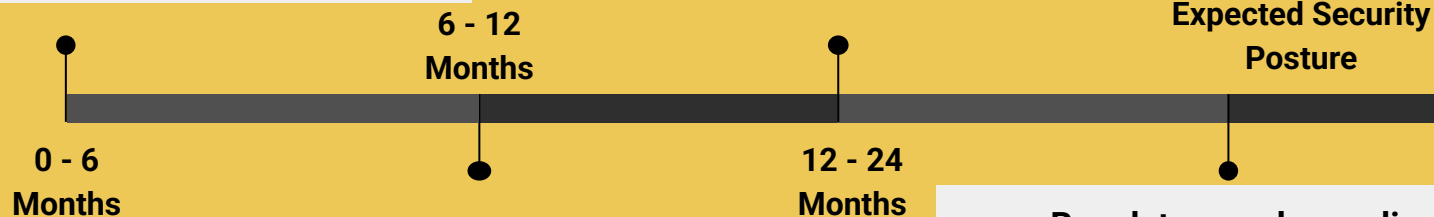
- Segment networks (IT vs OT).
- Enforce vendor security controls.
- Maintain offline, secure backups.
- Patch systems regularly.



TIMELINE Roadmap

- Enforce MFA
- Enterprise-wide access review
- Training & Awareness phishing simulations

- Zero Trust Architecture
- Red-Team/Blue-Team Exercises
- Vendor Risk Management Framework



- PAM Deployment
- Network Segmentation (IT & OT Environments)
- Full Pen-testing of Tier 3 assets
- Regular Vulnerability scanning program

- Regulatory and compliance readiness
- Vendor & Partner Trust
- Established Security Culture
- Business Continuity Protection
- Limited Breach Damage

Questions?

